



المدرسة الوطنية للعلوم التطبيقية - بني ملال

ⵜⴰⵎⴰⵔⵜ ⵜⴰⵎⴰⵏⴰⵢⵜ ⵜⴰⵔⴰⵎⴰⵏⴰⵢⵜ ⵜⴰⵔⴰⵎⴰⵏⴰⵢⵜ - ⵎⴰⵏⴰⵢⵜ ⵔⴰⵎⴰⵏⴰⵢⵜ

Ecole Nationale des Sciences Appliquées - Béni Mellal

ÉCOLE NATIONALE DES SCIENCES APPLIQUÉES DE BENI MELLAL

Université Sultan Moulay Slimane | Filière : IA & Cybersécurité

# CADRE DE GOUVERNANCE

## Conception d'un Système IA Responsable et Conforme au RGPD

Rédigé par

AGOURRAM Hajar  
BOUARAFA Sara

Encadrant

Pr. TOUIL

*Module : Éthique et Droit du Numérique*

Année universitaire : 2025-2026

## 1. Introduction et Objectifs

Le présent document définit le cadre de gouvernance éthique et organisationnel du système d'intelligence artificielle déployé au sein de l'École Nationale des Sciences Appliquées de Béni Mellal (ENSA). Il constitue l'un des livrables centraux du projet pédagogique du module Éthique et Droit du Numérique.

Ce cadre de gouvernance a pour vocation de garantir que le système IA est destiné à la génération de contenus automatisés, à l'assistance à la décision et au traitement de données non sensibles : est développé, déployé et opéré dans le respect des droits fondamentaux des personnes concernées, des exigences du RGPD et des principes éthiques de l'intelligence artificielle de confiance.

### 1.1 Périmètre d'Application

Ce cadre s'applique à :

- L'ensemble des composantes du système IA déployé à l'ENSA Béni Mellal ;
- Tous les acteurs impliqués dans son développement, son exploitation et son utilisation ;
- Toutes les données traitées dans le cadre du fonctionnement du système ;
- Toutes les décisions prises avec l'assistance du système IA.

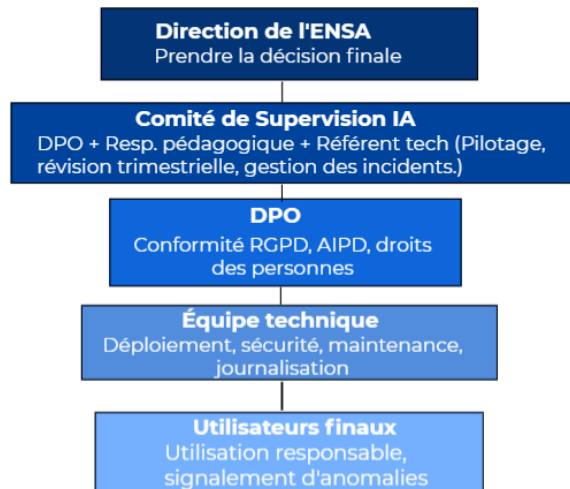
### 1.2 Objectifs de la Gouvernance

Le cadre de gouvernance poursuit six objectifs fondamentaux :

- Garantir la conformité permanente du système IA aux exigences du RGPD et du droit applicable ;
- Assurer une supervision humaine effective et documentée de toutes les décisions assistées par l'IA ;
- Promouvoir la transparence vis-à-vis des utilisateurs et de toutes les parties prenantes ;
- Attribuer clairement les responsabilités à chaque acteur de la chaîne de valeur ;
- Mettre en place des mécanismes robustes de contrôle, d'audit et d'amélioration continue ;
- Prévenir et traiter efficacement les risques éthiques, juridiques et techniques.

## 2. Structure de Gouvernance : Organigramme

La gouvernance du système IA de l'ENSA repose sur une architecture à cinq niveaux, articulant responsabilités stratégiques, opérationnelles, fonctionnelles, techniques et d'usage. Cette structure garantit une couverture complète des obligations de l'accountability définie par l'article 5.2 du RGPD.



| Niveau       | Instance                         | Composition                                        | Mission                                                                            |
|--------------|----------------------------------|----------------------------------------------------|------------------------------------------------------------------------------------|
| Stratégique  | Direction de l'ENSA              | Directeur de l'établissement                       | Décision finale, approbation de la politique IA, engagement public de conformité   |
| Opérationnel | Comité de Supervision IA         | DPO + Responsable pédagogique + Référent technique | Pilotage, révision trimestrielle, gestion des incidents, validation des évolutions |
| Fonctionnel  | DPO                              | Délégué à la Protection des Données désigné        | Conformité RGPD, AIPD, droits des personnes, liaison CNDP                          |
| Technique    | Équipe technique / Sous-traitant | Développeurs, administrateurs système              | Déploiement, sécurité, maintenance, journalisation                                 |
| Usage        | Utilisateurs finaux              | Étudiants et personnel de l'ENSA                   | Utilisation responsable, signalement d'anomalies, exercice des droits              |

### 2.1 Identification et Rôles des Acteurs

Chaque acteur du système IA se voit attribuer des responsabilités précises et non ambiguës, conformément aux dispositions du RGPD et aux principes de gouvernance IA. Le tableau ci-dessous détaille ces attributions :

| Acteur                    | Désignation                            | Rôle principal                                                                                 | Obligations RGPD                    |
|---------------------------|----------------------------------------|------------------------------------------------------------------------------------------------|-------------------------------------|
| Responsable de traitement | Direction de l'ENSA Béni Mellal        | Définit les finalités et moyens du traitement ; assume la responsabilité globale du système IA | Art. 5, 24, 25, 30, 35 RGPD         |
| Sous-traitant technique   | Hébergeur / prestataire infrastructure | Assure l'hébergement sécurisé, la disponibilité et la                                          | Art. 28 RGPD<br>Contrat obligatoire |

|                                                  |                                                           |                                                                                                |                                     |
|--------------------------------------------------|-----------------------------------------------------------|------------------------------------------------------------------------------------------------|-------------------------------------|
|                                                  |                                                           | maintenance technique du système                                                               |                                     |
| <b>Délégué à la Protection des Données (DPO)</b> | Désigné par la Direction de l'ENSA                        | Conseil juridique, contrôle de la conformité, point de contact CNDP, gestion de l'AIPD         | Art. 37-39 RGPD                     |
| <b>Comité de Supervision IA</b>                  | DPO + Responsable pédagogique + Référent technique        | Révision trimestrielle du système, détection des dérives, validation des évolutions            | Art. 35 RGPD<br>Révision AIPD       |
| <b>Utilisateur final</b>                         | Étudiants et personnel académique/administratif de l'ENSA | Utilise le système dans le respect de la politique d'utilisation ; responsable de ses requêtes | Sujet des droits<br>Art. 13-22 RGPD |

## 2.2 Matrice des Responsabilités

La matrice ci-dessous établit, pour chaque responsabilité clé du système, l'acteur principal et l'acteur secondaire impliqués, ainsi que la référence réglementaire applicable :

| Responsabilité                                | Acteur principal               | Acteur secondaire      | Référence                           |
|-----------------------------------------------|--------------------------------|------------------------|-------------------------------------|
| Définition des finalités du traitement        | <b>Responsable traitement</b>  | DPO                    | <a href="#">Art. 5 &amp; 6 RGPD</a> |
| Réalisation et mise à jour de l'AIPD          | <b>DPO</b>                     | Comité Supervision IA  | <a href="#">Art. 35 RGPD</a>        |
| Sécurité technique du système                 | <b>Sous-traitant technique</b> | Responsable traitement | <a href="#">Art. 32 RGPD</a>        |
| Formation et sensibilisation des utilisateurs | <b>DPO</b>                     | Direction pédagogique  | <a href="#">Art. 5.2 RGPD</a>       |
| Validation humaine des décisions académiques  | <b>Responsable pédagogique</b> | Comité Supervision IA  | <a href="#">Art. 22 RGPD</a>        |
| Traitement des demandes d'exercice de droits  | <b>DPO</b>                     | Responsable traitement | <a href="#">Art. 12-22 RGPD</a>     |
| Révision périodique de la gouvernance         | <b>Comité Supervision IA</b>   | DPO                    | <a href="#">Art. 24 RGPD</a>        |
| Notification en cas de violation de données   | <b>Responsable traitement</b>  | DPO                    | <a href="#">Art. 33 RGPD</a>        |

### 3. Mécanismes de Supervision Humaine

La supervision humaine constitue le pilier central de la gouvernance éthique du système IA. Conformément à l'article 22 du RGPD et aux principes de l'IA de confiance définis par la Commission Européenne dans ses Lignes directrices éthiques pour une IA digne de confiance (2019), le système garantit un contrôle humain effectif sur toutes les décisions susceptibles d'affecter significativement les personnes concernées.

#### 3.1 Deux Régimes de Supervision Distincts

Le système distingue deux régimes d'application de l'article 22 RGPD selon la nature et l'impact de la décision :

| Régime          | Type de décision                                                                | Circuit                                                                                                                          | Art. 22 RGPD                                                                        |
|-----------------|---------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| <b>Régime 1</b> | Réponses d'assistance simple (résumés, explications, questions pédagogiques)    | Transmise directement à l'utilisateur avec avertissement obligatoire sur le caractère automatique de la réponse                  | Non applicable<br>aucun effet<br>juridique<br>significatif                          |
| <b>Régime 2</b> | Décisions à impact académique (évaluations, orientations, résultats, sanctions) | 1) Suggestion IA générée<br>2) Validation humaine obligatoire (responsable habilité)<br>3) Communication à la personne concernée | <b>Pleinement<br/>applicable<br/>validation<br/>humaine AVANT<br/>communication</b> |

#### 3.2 Circuit de Validation Humaine (Régime 2)

Pour toute décision à impact académique, le circuit de validation suivant est obligatoire et doit être documenté dans le journal de traçabilité :

- **Le système IA génère une suggestion ou recommandation, enregistrée automatiquement dans le journal avec horodatage et identifiant pseudonymisé** : Étape 1 : Génération
- **Un responsable humain habilité examine la suggestion, peut la valider, la modifier ou la rejeter. Son identité et la date d'approbation sont consignées** : Étape 2 : Révision humaine
- **Seule la décision validée par le responsable humain est communiquée à la personne concernée. La suggestion IA brute n'est jamais transmise directement** : Étape 3 : Communication

#### 3.3 Procédure de Contestation

Tout utilisateur dispose du droit de contester une réponse ou une décision assistée par le système IA. La procédure est la suivante :

- Soumission d'une demande de contestation via le formulaire dédié ou par contact direct avec le DPO ;
- Accusé de réception dans un délai de 48 heures ;
- Examen de la contestation par le Comité de Supervision IA dans un délai de 5 jours ouvrés ;
- Notification de la décision rendue, avec justification, dans un délai de 10 jours ouvrés ;
- Possibilité de recours auprès de la Direction de l'ENSA en cas de désaccord persistant.

#### 3.4 Traçabilité des Décisions

Chaque interaction avec le système IA fait l'objet d'une journalisation complète incluant :

- Identifiant pseudonymisé de l'utilisateur ;
- Horodatage précis (date, heure, fuseau horaire) ;
- Nature de la requête (catégorie fonctionnelle) ;
- Statut de la réponse (assistée simple / soumise à validation) ;
- Identité et date de validation du responsable humain (pour le Régime 2) ;
- Résultat final communiqué à l'utilisateur.

## 4. Exigences de Transparence

La transparence constitue un droit fondamental des personnes concernées par le système IA, consacré par les articles 13 et 14 du RGPD. Elle est également au cœur des principes de l'IA de confiance définis par la Commission Européenne. Le présent cadre définit cinq niveaux d'exigences de transparence :

| Exigence de transparence                             | Modalité de mise en œuvre                                                                                                                                                                    | Référence                                                   |
|------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------|
| <b>Information préalable à l'utilisation</b>         | Notice claire et accessible indiquant l'usage d'un système IA, ses capacités et ses limites, affichée avant toute première interaction                                                       | <a href="#">Art. 13 RGPD + Principe de transparence</a>     |
| <b>Avertissement systématique sur chaque réponse</b> | Message standard affiché sur toutes les réponses : "Cette réponse a été générée automatiquement par un système d'IA. Une validation humaine est recommandée pour toute décision importante." | <a href="#">Art. 22 RGPD + Principes IA de confiance UE</a> |
| <b>Explication du fonctionnement général</b>         | Documentation technique accessible expliquant en termes non techniques comment le système génère ses réponses et les données qu'il utilise                                                   | <a href="#">Art. 13 §2.f RGPD</a>                           |
| <b>Documentation des limitations et risques</b>      | Registre public des cas d'usage non appropriés, des risques d'erreur (hallucinations), et des domaines où la réponse de l'IA doit être vérifiée systématiquement                             | <a href="#">Principes IA de confiance UE 2019</a>           |
| <b>Rapport annuel de gouvernance</b>                 | Publication d'un rapport annuel sur l'utilisation du système, les incidents détectés, les droits exercés et les améliorations apportées                                                      | <a href="#">Art. 5.2 RGPD :Accountability</a>               |

### 4.1 Contenu Obligatoire de la Notice d'Information (Art. 13 RGPD)

La notice d'information affichée avant toute utilisation du système doit contenir au minimum les éléments suivants :

- Identité et coordonnées du responsable de traitement (ENSA Béni Mellal) ;
- Coordonnées du DPO et modalités de contact ;
- Finalités et base légale du traitement (Art. 6.1.e RGPD :mission d'intérêt public) ;
- Nature des données collectées et durée de conservation ;
- Droits des personnes et modalités d'exercice ;
- Existence d'un traitement automatisé et ses implications ;
- Interdiction explicite de saisir des données personnelles ou sensibles.

## 5. Mécanismes d'Audit et de Contrôle

Le cadre de gouvernance prévoit un ensemble de mécanismes de contrôle périodiques garantissant la conformité continue du système IA et l'amélioration de sa gouvernance. Ces mécanismes traduisent concrètement le principe d'accountability de l'article 5.2 du RGPD.

| Mécanisme de contrôle                      | Fréquence     | Responsable                 | Livrables attendus                                   |
|--------------------------------------------|---------------|-----------------------------|------------------------------------------------------|
| Révision de l'AIPD                         | Annuelle      | DPO + Comité Supervision IA | AIPD mise à jour et signée                           |
| Audit de conformité RGPD                   | Annuelle      | DPO                         | Rapport d'audit et plan de remédiation               |
| Revue des logs et des accès                | Trimestrielle | Responsable technique       | Tableau de bord des accès et anomalies détectées     |
| Révision de la politique d'utilisation     | Annuelle      | DPO + Direction             | Politique mise à jour et rediffusée aux utilisateurs |
| Test de sécurité (pentest)                 | Annuelle      | Sous-traitant technique     | Rapport de test et correctifs appliqués              |
| Évaluation de la satisfaction utilisateurs | Semestrielle  | Direction pédagogique       | Résultats d'enquête et plan d'amélioration           |
| Révision du comité de supervision          | Trimestrielle | Comité Supervision IA       | Compte-rendu de réunion et décisions actées          |

### 5.1 Rôle du Comité de Supervision IA

Le Comité de Supervision IA est l'organe central de contrôle du système. Il se réunit trimestriellement et a pour missions :

- Examiner les indicateurs de performance et de conformité du système ;
- Analyser les incidents et anomalies détectés depuis la dernière réunion ;
- Valider les évolutions fonctionnelles et techniques du système ;
- Décider des mesures correctives en cas de dérive identifiée ;
- Proposer des mises à jour du présent cadre de gouvernance ;
- Produire un compte-rendu de chaque réunion, archivé et accessible au DPO.

### 5.2 Indicateurs Clés de Conformité (KPI)

Les indicateurs suivants sont mesurés et reportés trimestriellement par le Comité de Supervision IA :

- Taux de validation humaine des décisions de Régime 2 (objectif : 100%) ;
- Délai moyen de traitement des demandes d'exercice de droits (objectif : < 30 jours) ;
- Nombre d'incidents de sécurité ou de violations de données détectés ;
- Taux de satisfaction des utilisateurs vis-à-vis du système et de son fonctionnement ;
- Nombre de contestations reçues et délai moyen de traitement ;
- Couverture de formation des utilisateurs (objectif : 100% avant premier accès).



## 6. Gestion des Incidents et des Violations de Données

Conformément aux articles 33 et 34 du RGPD, le cadre de gouvernance prévoit une procédure formalisée de gestion des incidents de sécurité et des violations de données à caractère personnel. Cette procédure doit être connue de tous les acteurs impliqués.

| Phase                | Action                                                                  | Responsable                                | Délai                | Référence                    |
|----------------------|-------------------------------------------------------------------------|--------------------------------------------|----------------------|------------------------------|
| <b>Détection</b>     | Identification de l'incident (violation, anomalie, dysfonctionnement)   | <b>Utilisateur / Responsable technique</b> | <b>Immédiat</b>      | <a href="#">Art. 33 RGPD</a> |
| <b>Évaluation</b>    | Qualification de la gravité et de l'impact sur les personnes concernées | <b>DPO</b>                                 | <b>&lt; 24h</b>      | <a href="#">Art. 33 RGPD</a> |
| <b>Notification</b>  | Notification à la CNDP si risque pour les droits et libertés            | <b>Responsable traitement + DPO</b>        | <b>&lt; 72h</b>      | <a href="#">Art. 33 RGPD</a> |
| <b>Containment</b>   | Isolement du système ou de la fonctionnalité défaillante                | <b>Responsable technique</b>               | <b>&lt; 4h</b>       | <a href="#">Art. 32 RGPD</a> |
| <b>Information</b>   | Information des personnes concernées si risque élevé                    | <b>DPO</b>                                 | <b>Sans délai</b>    | <a href="#">Art. 34 RGPD</a> |
| <b>Remédiation</b>   | Correction, restauration et vérification du système                     | <b>Sous-traitant + Responsable</b>         | <b>&lt; 72h</b>      | <a href="#">Art. 32 RGPD</a> |
| <b>Post-incident</b> | Rapport d'incident, analyse des causes, mise à jour de l'AIPD           | <b>DPO + Comité Supervision IA</b>         | <b>&lt; 30 jours</b> | <a href="#">Art. 35 RGPD</a> |

### 6.1 Définition des Incidents

Constituent des incidents soumis à cette procédure :

- Toute violation de données à caractère personnel (accès non autorisé, divulgation, perte, destruction) ;
- Tout dysfonctionnement du système IA produisant des réponses incorrectes ou discriminatoires ;
- Toute tentative de saisie ou de traitement de données sensibles au sens de l'article 9 RGPD ;
- Tout accès non autorisé au système ou à ses journaux ;
- Toute décision automatisée transmise sans validation humaine en violation du Régime 2.

### 6.2 Registre des Incidents

Un registre des incidents est tenu par le DPO. Il consigne pour chaque incident : la date et l'heure de détection, la nature et l'étendue de l'incident, les personnes concernées, les mesures prises et les enseignements tirés. Ce registre est revu lors de chaque réunion du Comité de Supervision IA.

## 7. Révision et Mise à Jour du Cadre de Gouvernance

### 7.1 Fréquence de Révision

Le présent cadre de gouvernance fait l'objet d'une révision obligatoire dans les cas suivants :

- Révision annuelle systématique, pilotée par le DPO et validée par la Direction ;
- Révision exceptionnelle en cas de modification substantielle du système IA ou de ses finalités ;
- Révision exceptionnelle en cas de changement réglementaire impactant le traitement (nouveau règlement, décision de la CNDP) ;
- Révision exceptionnelle après tout incident majeur de sécurité ou violation de données.

### 7.2 Processus de Validation

Toute révision du cadre de gouvernance suit le processus suivant :

- Proposition de modifications par le DPO ou le Comité de Supervision IA ;
- Consultation des utilisateurs représentatifs et des parties prenantes concernées ;
- Validation par le Comité de Supervision IA ;
- Approbation finale par la Direction de l'ENSA ;
- Diffusion de la nouvelle version à tous les acteurs concernés et publication sur l'espace documentaire dédié.

### 7.3 Historique des Révisions

| Version | Date      | Modifications                                                                               | Auteur        |
|---------|-----------|---------------------------------------------------------------------------------------------|---------------|
| 1.0     | 2025-2026 | Version initiale : création du cadre de gouvernance dans le cadre du projet pédagogique EDN | Équipe projet |

## 8. Conclusion

Le présent cadre de gouvernance définit un dispositif complet et structuré pour assurer le déploiement responsable, transparent et conforme du système IA de l'ENSA Béni Mellal. Il couvre l'ensemble des dimensions exigées par le RGPD et les principes éthiques de l'IA de confiance : identification des acteurs et de leurs responsabilités, supervision humaine différenciée selon l'impact des décisions, exigences de transparence, mécanismes d'audit et procédures de gestion des incidents.

Ce cadre n'est pas un document figé : il constitue un engagement vivant, soumis à révision régulière, qui doit évoluer avec le système IA et avec le contexte réglementaire. Sa mise en œuvre effective repose sur l'engagement de tous les acteurs identifiés, depuis la Direction jusqu'aux utilisateurs finaux, dans le respect des droits des personnes concernées et de l'intérêt général de la communauté de l'ENSA.

## 9. Références Réglementaires

- Règlement (UE) 2016/679 du Parlement européen et du Conseil du 27 avril 2016 (RGPD) ;
- Lignes directrices éthiques pour une IA digne de confiance, Commission Européenne, Groupe d'experts de haut niveau sur l'IA, 2019 ;
- Lignes directrices du CEPD sur l'Analyse d'Impact (AIPD) -WP248 ;
- Proposition de Règlement sur l'Intelligence Artificielle (AI Act), Commission Européenne, 2021 ;
- Recommandation CM/Rec(2020)1 du Comité des Ministres du Conseil de l'Europe ;
- Guidelines 04/2022 du CEPD sur le calcul des amendes administratives (Art. 83 RGPD).